

MAPEO DETALLADO: PREGUNTAS GQM → REQUISITOS NORMATIVOS

Trazabilidad de Indicadores NIST AI RMF a EU AI Act, NIS2, GDPR, ISO 27001

Versión: 2.0

Fecha: Enero 2026

Clasificación: Profesional | Documentación Técnica

Contexto: España | Cumplimiento normativo integrado

Scope: EU AI Act Art. 1-99 + NIS2 Directiva + GDPR Art. 1-99 + ISO 27001 A.1-A.14

I. MATRIZ MAESTRA: PREGUNTA GQM → NORMATIVA APLICABLE

Nomenclatura

- GOAL: Objetivo estratégico España
- Q: Pregunta operacional (GQM Nivel 2)
- M: Métrica (GQM Nivel 3)
- EU AI: Artículos EU AI Act aplicables
- NIS2: Artículos/Requisitos NIS2
- GDPR: Artículos GDPR
- ISO 27001: Cláusulas ISO
- Requisito Concreto: Acción obligatoria en España

II. MÓDULO 1: GOBERNANZA (GOVERN)

1.1 Política Formal de IA

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Gobernar riesgos IA en decisiones críticas	EU AI Act	Art. 5	Sistema gestión riesgos documentado
Q	¿Existe política IA formal aprobada por Board?	EU AI Act + NIS2	Art. 5 + Art. 18	Política escrita, aprobada, comunicada
M	Binary (Sí/No); Existence date	EU AI Act	Art. 5, 9	Documentación accesible para auditoría
Acción Obligatoria	Documentar política que cubra:			
	- Propósito y scope	EU AI Act	Art. 5(1)	Todos sistemas IA > €100K presupuesto anual
	- Risk tolerance scales	EU AI Act	Art. 5(1)	Escalas RAG por función (GOVERN, MAP, MEASURE)
	- Governance estructura (RACI)	EU AI Act	Art. 6	Roles claros: Owner, Accountable, Consulted, Informed
	- Escalation paths	NIS2	Art. 18	Cadena escalada hasta C-level
	- Revisión cadencia	NIS2	Art. 18	Anual + triggered por cambios regulatorios
Timeline	Q1 2026 (antes EU AI Act enforcement)	Timing	Feb 2026	Aprobación Board antes 2 Feb 2026
Evidencia	Policy document + Board resolution + distribution log	Audit		Archivo centralizado accesible auditor
Compliance Maturity	Nivel 3 NIST (Defined/Estándar)	NIST	GOVERN-1	Policies operacionalizadas , no shelf-ware

1.2 RACI Matrix Formalización

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Claridad de responsabilidades en decisiones IA críticas	EU AI Act + NIS2	Art. 6 + Art. 20	Accountabilities documentadas
Q	¿RACI documentado y operacionalizado para decisiones críticas?	EU AI Act	Art. 6(1)	Provider / Deployer roles explícitos
M	% decisiones críticas con RACI asignado; Stakeholder awareness >80%	NIS2	Art. 20	RACI coverage ≥80% de decisiones high-impact
Acción Obligatoria	Definir RACI para ≥10 decisiones críticas:			
	1. IA system approval	EU AI Act	Art. 28-30	Provider / Deployer approval gates
	2. Risk assessment	EU AI Act	Art. 9	Risk Management System responsibility
	3. Fairness audit trigger	EU AI Act	Art. 15	Fairness testing requirement
	4. Incident escalation	NIS2	Art. 18	Incident response chain
	5. Compliance validation	EU AI Act	Art. 43-50	Conformity assessment responsibility
	(etc. 5 more)			
Roles Defined				
	Responsible: Executes decision	EU AI Act	Art. 3	Provider / Deployer as defined
	Accountable: Final authority	EU AI Act	Art. 6	C-level (CEO/CISO/CDO)
	Consulted: Input (e.g., Ethics)	EU AI Act	Art. 5	Ethics committee, Legal
	Informed: Notification	EU AI Act	Art. 5	Board, Compliance, Business leads

Documentation	RACI matrix in wiki + training evidence	NIS2	Art. 20	All staff understand their roles
Validation	External audit verifies RACI adherence	Audit		External auditor confirms
Timeline	Q1 2026 completion	Timing	Feb 2026	Ready for AESIA audit

1.3 Risk Tolerance Quantificado

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Establecer límites cuantitativos de riesgo aceptable	EU AI Act	Art. 5(2)	Risk tolerance per dimension
Q	¿Tolerancia de riesgo documentada en escalas cuantitativas?	EU AI Act	Art. 5(2)	RAG scales for all risk types
M	# dimensions con tolerance ranges definidos / 7 trustworthiness dims	EU AI Act	Art. 6	Target: 100% (7/7 dimensions)
Acción Obligatoria	Definir escalas cuantitativas para:			
	Accuracy (Valid & Reliable)	EU AI Act	Art. 15	Baseline ≥95%, disparity <5%
	Bias/Fairness	EU AI Act	Art. 14	Demographic parity gap <5%
	Security (Secure & Resilient)	NIS2	Art. 20	MTTD <15 min; MTTR <30 days
	Explainability (Transparency)	EU AI Act	Art. 50	Explanation coverage >90%
	Privacy-Enhanced	GDPR	Art. 32	Data minimization; PET >80%
	Accountability (Audit Trail)	EU AI Act	Art. 12	Logging 100%; retention 24 months
	Safety/Robustness	EU AI Act	Art. 15	Residual risk <5% post-mitigation
Escalation Triggers				
	YELLOW: Tolerance approached (85%)	Internal Policy		Alert to Risk Committee
	RED: Tolerance exceeded (100%)	EU AI Act	Art. 29	Escalate to Board; cannot deploy

Board Approval	Tolerance scales approved by Board Risk Committee	NIS2	Art. 18	Documented resolution + date
Review Cadence	Annual + triggered by regulatory change	EU AI Act	Art. 5	Semi-annual minimum
Validation	External risk expert validates scales annually	Audit		Independent calibration check

1.4 IA System Inventory

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Visibilidad completa de sistemas IA en organización	EU AI Act	Art. 28	Registry requirement for high-risk
Q	¿Inventario centralizado con cobertura >95%?	EU AI Act	Art. 6	All IA systems catalogued
M	Discrepancy rate <2% (3 independent audits align)	EU AI Act	Art. 28	Verified completeness
Acción Obligatoria	Catalogar sistemas con atributos:			
	System name, description	EU AI Act	Art. 28	Clear identification
	Purpose, deployment context	EU AI Act	Art. 6	Intended use documented
	Risk tier (low/med/high/critical)	EU AI Act	Art. 6	Per Annex I/III classification
	Owner (business + technical)	EU AI Act	Art. 6	Accountability clear
	Training data source	EU AI Act	Art. 10	Data governance traceability
	Pre-trained model provenance	EU AI Act	Art. 28	Supply chain visibility
	Deployment environment	EU AI Act	Art. 28	Where/how deployed
	Audit status	EU AI Act	Art. 43	Conformity assessment status
	Fairness audit date	EU AI Act	Art. 14-15	Most recent bias review
	Last security assessment	NIS2	Art. 18	Most recent pentesting
	Compliance checklist (Art. 9-15)	EU AI Act	Art. 9-15	Status per article
Database	Centralized system (ServiceNow, Archer, custom)	EU AI Act	Art. 6	Accessible to CISO, Audit, AESIA

Scanning	Automated quarterly + manual annual audit	EU AI Act	Art. 28	Continuous discovery
Validation	Independent audit: 3rd recount; discrepancies <2%	EU AI Act	Art. 28	External verification
High-Risk Registration	All high-risk systems registered in EU database	EU AI Act	Art. 49	By Aug 2 2026 deadline
Timeline	Baseline Q1 2026; full inventory Q2 2026	Timing	Before June 2026	Ready for EU database registration

III. MÓDULO 2: MAPEO (MAP)

2.1 Stakeholder Impact Assessment

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Comprender impacto en todos stakeholders; mitigar daño	EU AI Act	Art. 5 + Art. 14	Fairness Impact Analysis (FRIA)
Q	¿Análisis de impacto en stakeholders completado pre-deployment?	EU AI Act	Art. 5	Impact assessment mandatory
M	# stakeholder groups consulted (target ≥5); feedback incorporated (≥70%)	EU AI Act	Art. 5 + Art. 14	Participatory assessment required
Acción Obligatoria	Consultar mínimo 5 grupos:			
	1. End users/citizens impacted	GDPR	Art. 13	Informed consent; transparency
	2. Data sources (origin de data)	GDPR	Art. 14	Data subjects' rights
	3. Domain experts	EU AI Act	Art. 5	Technical feasibility review
	4. Affected communities (vulnerable groups)	EU AI Act	Art. 5	Equitable impact analysis
	5. Compliance/Legal/Ethics	EU AI Act	Art. 5	Regulatory alignment check
Impact Register	Document:			
	- Rights affected (per GDPR)	GDPR	Art. 13-14	Fundamental rights assessment
	- Vulnerable groups exposure	EU AI Act	Art. 5	Special categories (per GDPR Art. 9)
	- Beneficial outcomes	EU AI Act	Art. 5	Positive societal impact
	- Negative outcomes possible	EU AI Act	Art. 5	Harms identified pre-deployment

	- Mitigation measures	EU AI Act	Art. 5	Risk reduction strategies
	- Monitoring plan	EU AI Act	Art. 5	Post-deployment surveillance
Facilitation	External facilitator (not product team) to avoid bias	EU AI Act	Art. 5	Independent assessment
Documentation	Impact register + workshop notes + stakeholder feedback + decisions	GDPR	Art. 32	Audit trail for compliance
Timeline	Pre-deployment; updated annually for operational systems	EU AI Act	Art. 5	Before market placement

2.2 Risk Matrix (Impact × Likelihood)

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Priorizar riesgos para asignación de recursos	EU AI Act	Art. 5 + Art. 9	Risk management system
Q	¿Risk matrix definida y usada en go/no-go decisions?	EU AI Act	Art. 9	Risk assessment required
M	% decisiones deployment usando matrix (target 100%)	EU AI Act	Art. 9	Gate criteria enforced
Acción Obligatoria	Definir Impact & Likelihood scales:			
	Impact Scale (1-5)	EU AI Act	Art. 9	
	1 = Negligible (<€100K loss; <10 people)	EU AI Act	Art. 6	Low-risk threshold
	2 = Minor (€100K-1M; 10-100 people)	EU AI Act	Art. 6	Limited-risk
	3 = Moderate (€1-10M; 100-1K people)	EU AI Act	Art. 6	Medium-risk
	4 = Major (€10-100M; 1K-10K people)	EU AI Act	Art. 6	High-risk threshold
	5 = Critical (>€100M; >10K people OR systemic)	EU AI Act	Art. 6	Very high-risk (> sanciones AESIA)
	Likelihood Scale (1-5, annual)	EU AI Act	Art. 9	
	1 = Rare (<1% probability)	EU AI Act	Art. 9	Residual risk
	2 = Unlikely (1-5%)	EU AI Act	Art. 9	Very low probability
	3 = Possible (5-20%)	EU AI Act	Art. 9	Moderate probability
	4 = Likely (20-50%)	EU AI Act	Art. 9	High probability
	5 = Almost certain (>50%)	EU AI Act	Art. 9	Imminent risk

	Risk Acceptance Criteria	EU AI Act	Art. 9	
	High-risk (Impact 4-5 × Likelihood 3+): Cannot deploy without Board approval	EU AI Act	Art. 29	Escalation mandatory
	Medium-risk (Impact 3 × Likelihood 2-3): Mitigation required	EU AI Act	Art. 5	Risk reduction plan
	Low-risk (Impact 1-2 × Likelihood 1-2): Proceed with standard monitoring	EU AI Act	Art. 5	Standard post-deployment tracking
Matrix Calibration	External risk expert reviews annually	EU AI Act	Art. 9	Against actual incidents (ground truth)
Risk Register	Tracked in centralized system (Archer, ServiceNow)	ISO 27001	A.12.6	Risk register maintained
Post-Incident Review	Compare forecast vs. actual; update matrix if needed	ISO 27001	A.16.1	Continuous improvement
Timeline	Baseline risk scoring Q1 2026; recurring quarterly	EU AI Act	Art. 9	Before deployment gates

IV. MÓDULO 3: MEDICIÓN (MEASURE)

3.1 Accuracy/Reliability Monitoring

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Asegurar modelos funcionan per designed purpose	EU AI Act	Art. 15	Accuracy/robustness requirement
Q	¿Accuracy monitoreado continuamente en producción?	EU AI Act	Art. 15	Ongoing accuracy monitoring
M	Holdout accuracy $\geq 95\%$; Production accuracy $\geq 94\%$; drift alerts $< 2\%$ MoM	EU AI Act	Art. 15	Measurable performance thresholds
Acción Obligatoria	Monitorear:			
	Holdout test accuracy (weekly)	EU AI Act	Art. 15	Baseline performance stable
	Production accuracy (monthly sampled)	EU AI Act	Art. 15	Real-world performance tracked
	Accuracy per demographic group	EU AI Act	Art. 14-15	Disparity detection
	Trending: $\uparrow$ stable, or $\downarrow$?	NIS2	Art. 20	Drift mitigation if declining
Alert Thresholds		EU AI Act	Art. 15	
	YELLOW: $< 95\%$ holdout OR $\downarrow 2\%$ MoM	EU AI Act	Art. 15	Investigate root cause
	RED: $< 92\%$ holdout OR $\downarrow 5\%$ MoM	EU AI Act	Art. 15	Model disabled until retrained
Remediation	If RED: Retrain, validate, re-deploy	EU AI Act	Art. 15	MTTR < 30 days
Documentation	Model Card per model (trained date, performance metrics, limitations)	EU AI Act	Art. 13	Technical documentation requirement

Audit Trail	All accuracy measurements logged (timestamp, performer, results)	EU AI Act	Art. 12	Audit trail for conformity assessment
Timeline	Weekly holdout checks; monthly production sampling	EU AI Act	Art. 15	Continuous monitoring

3.2 Fairness/Bias Monitoring (Demographic Parity)

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Evitar discriminación sistemática en decisiones IA	EU AI Act	Art. 14	Fairness requirement
Q	¿Bias auditado regularmente; gap <5%?	EU AI Act	Art. 14-15	Mandatory fairness testing
M	Demographic parity gap <5% (approval rate difference between groups)	EU AI Act	Art. 15	Quantified fairness metric
Acción Obligatoria	Auditar fairness:			
	Demographic groups: Gender, Age, Nationality, etc.	EU AI Act	Art. 14	Per Annex I/III categories
	Fairness metrics:	EU AI Act	Art. 15	
	- Demographic Parity: <5% gap	EU AI Act	Art. 15	Statistical fairness
	- Equalized Odds: FPR gap <3%	EU AI Act	Art. 15	Error rate fairness
	- Calibration: Probability ≈ outcome per group	EU AI Act	Art. 15	Predictive fairness
	Frequency: Monthly automated, Quarterly audit	EU AI Act	Art. 15	Continuous + formal review
Alert Thresholds		EU AI Act	Art. 14-15	
	YELLOW: Gap 5-7.5%	EU AI Act	Art. 14	Escalate to Chief Architect
	RED: Gap >7.5%	EU AI Act	Art. 14	Model disabled; board notification
Remediation	If RED: Root cause analysis, retrain, retest, deploy	EU AI Act	Art. 15	MTTR <30 days
	External fairness auditor validates methodology	EU AI Act	Art. 15	Independent verification (Aequitas team)

Training Data Review	Bias audit on training data: balance per demographic	EU AI Act	Art. 10	Data quality management
Monitoring	Post-deployment: monthly sampling; auto-alerts if gap > threshold	EU AI Act	Art. 5	Operational oversight
Documentation	Fairness audit report; bias register; mitigation decisions	EU AI Act	Art. 12-13	Technical documentation
Timeline	Baseline audit Q1-Q2 2026; operational monitoring 2026+	EU AI Act	Art. 15	Before Art. 50 deadline (Aug 2026)

3.3 Explainability (Transparency)

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Usuarios entienden decisiones IA; derecho a explicación	EU AI Act	Art. 50	Transparency requirement
Q	¿% decisiones que generan explicación automática?	EU AI Act	Art. 50	Explainability mandatory for high-risk
M	Coverage >95%; User satisfaction ≥6/10 (NPS)	EU AI Act	Art. 50	Meaningful transparency
Acción Obligatoria	Implementar explicabilidad:			
	Feature importance (top 3-5 features influencing decision)	EU AI Act	Art. 50	SHAP/LIME values
	Decision rule in plain language	EU AI Act	Art. 50	Non-technical explanation
	Uncertainty bounds (confidence interval)	EU AI Act	Art. 50	What system doesn't know
	Presented at decision time to user	EU AI Act	Art. 50	Transparency on-demand
User Testing	Survey (quarterly): "Was explanation helpful?" (1-10 scale)	EU AI Act	Art. 50	User satisfaction tracked
	Stratified by demographic (equity check)	EU AI Act	Art. 14	Fairness of explanation
	Track: # users requesting explanation (uptake)	EU AI Act	Art. 50	Usage metrics

Alert Threshold	Coverage <80% OR satisfaction <5/10 → block deployment	EU AI Act	Art. 50	Enforcement
Methodology	External UX testing quarterly	EU AI Act	Art. 50	Independent validation
Audit Trail	All explanations logged (decision, features, timestamp)	EU AI Act	Art. 12	Audit trail requirement
Timeline	Baseline coverage Q1-Q2 2026	EU AI Act	Art. 50	Before Aug 2 2026 enforcement

3.4 Security Monitoring (MTTD)

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Detectar anomalías de seguridad rápidamente	NIS2	Art. 18	MTTD requirement
Q	¿Anomalías detectadas en <15 minutos?	NIS2	Art. 18	Rapid threat detection
M	MTTD <15 min critical; <1 hour high alerts	NIS2	Art. 18	Quantified alert time
Acción Obligatoria	SIEM monitorea:	NIS2	Art. 18	
	Model drift detection (accuracy ↓ >2% MoM)	EU AI Act	Art. 15	Degradation alerts
	Suspicious model access (extraction attempts)	NIS2	Art. 18	Security threat
	Data exfiltration patterns	GDPR	Art. 32	Data breach prevention
	Supply chain incidents (malicious packages)	NIS2	Art. 18	Dependency compromise
	Compliance violations (audit trail tampering)	EU AI Act	Art. 12	Integrity threat
Alert Types		NIS2	Art. 18	
	Critical: MTTD <15 min	NIS2	Art. 18	Immediate escalation
	High: MTTD <1 hour	NIS2	Art. 18	Same-day response
	Medium: MTTD <8 hours	NIS2	Art. 18	Next business day
Escalation	YELLOW: MTTD >30 min → escalate to CISO	NIS2	Art. 18	Management review
	RED: MTTD >1 hour → board notification	NIS2	Art. 18	Executive escalation

Dashboard	Real-time SIEM + trend reporting (monthly)	NIS2	Art. 18	Visibility
NIS2 Reporting	Incidents >MTTD threshold reported to INCIBE within 24h	NIS2	Art. 20	Regulatory notification
Timeline	SIEM MTTD tracking live Q1 2026; NIST MTTD <15 min target Q3 2026	NIS2	Art. 18	Continuous

V. MÓDULO 4: GESTIÓN (MANAGE)

4.1 Remediación (MTTR)

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Resolver incidentes rápidamente; minimizar daño	NIS2	Art. 20	Incident response requirement
Q	¿Incidentes remediados en <30 días?	NIS2	Art. 20	MTTR SLA
M	MTTR <7 days critical; <30 days high incidents	NIS2	Art. 20	Quantified remediation time
Acción Obligatoria	Playbooks documentados para:	NIS2	Art. 20	
	Bias incident response	EU AI Act	Art. 14-15	Model disable; retrain; validate
	Security breach response	NIS2	Art. 18	Contain, forensics, remediate, notify
	Data privacy incident	GDPR	Art. 33	Notification <72h
	Supply chain compromise	NIS2	Art. 18	Dependency replacement
	Compliance violation	EU AI Act	Art. 29	AESIA reporting
Stages Tracked		NIS2	Art. 20	
	T1: Detection – Investigation: <1 day	NIS2	Art. 20	Alert triage
	T2: Investigation – RCA identified: <2 days	NIS2	Art. 20	Diagnostics
	T3: RCA – Remediation deployed: <7 days	NIS2	Art. 20	Fix execution
	T4: Deployment – Validation complete: <3 days	EU AI Act	Art. 15	Verification
MTTR SLA per Severity		NIS2	Art. 20	
	Critical: <7 days	NIS2	Art. 20	Highest priority
	High: <14 days	NIS2	Art. 20	Urgent

	Medium: <30 days	NIS2	Art. 20	Standard
	Low: <90 days	NIS2	Art. 20	Backlog
Escalation	MTTR >SLA → board notification	NIS2	Art. 18	Executive awareness
Audit Trail	All remediation steps logged + validated by independent auditor	EU AI Act	Art. 12	Conformity evidence
Timeline	Incident response SLAs operational Q1 2026; trending improvement 2026+	NIS2	Art. 20	Continuous

4.2 Validación de Remediación

Elemento	Detalle	Normativa	Artículo	Requisito Concreto
GOAL	Verificar que remediación efectivamente resolvió issue	EU AI Act	Art. 15	Post-remediation validation
Q	¿% remediaciones auditadas por tercero independiente?	EU AI Act	Art. 43	Conformity assessment
M	Validation coverage 100% critical/high; 50% sampling medium incidents	EU AI Act	Art. 43	Verified compliance
Acción Obligatoria	External auditor valida:	EU AI Act	Art. 43	
	Root cause addressed?	EU AI Act	Art. 15	RCA accuracy check
	Metrics back to acceptable thresholds?	EU AI Act	Art. 15	Performance confirmed
	No regressions introduced?	EU AI Act	Art. 15	Side-effect check
	Audit trail documented?	EU AI Act	Art. 12	Evidence collection
Audit Checklist	Bias incident:	EU AI Act	Art. 14-15	
	☐ Retraining completed with balanced data	EU AI Act	Art. 10	Data governance
	☐ Fairness metrics <5% gap on holdout	EU AI Act	Art. 15	Fairness verified
	☐ A/B test (old vs. new model) performed	EU AI Act	Art. 15	Validation method
	☐ Decision threshold approved by Board	EU AI Act	Art. 29	Governance gate
	☐ Model card updated	EU AI Act	Art. 13	Documentation
	Security incident:	NIS2	Art. 18	
	☐ Patch applied + tested	NIS2	Art. 18	Fix verification

	☐ SIEM detection updated (prevent recurrence)	NIS2	Art. 18	Prevention
	☐ Forensic report completed	NIS2	Art. 18	Root cause documented
Audit Pass Rate	Target >95% first-time pass (indicates quality)	EU AI Act	Art. 43	Quality metric
Rework	If audit FAIL: remediation re-done; re-audited	EU AI Act	Art. 15	Quality assurance
Timeline	Validation within 2 weeks post-remediation	EU AI Act	Art. 43	Time-bound
Sampling Strategy	Phase 1 (2026): 100% audit critical/high incidents	EU AI Act	Art. 43	Full coverage initially
	Phase 2 (2027+): If pass rate >97%, move to 50% sampling	EU AI Act	Art. 43	Efficiency gains

VI. TABLA SUMARIA: TODAS LAS PREGUNTAS + NORMATIVA

#	Pregunta QQM	Métrica	EU AI Act	NIS2	GDPR	ISO 27001	Compliance Owner
1.1	Política formal?	Binary	Art. 5,6	Art. 18	-	A.5.1	General Counsel + CISO
1.2	RACI documentado?	% coverage	Art. 6	Art. 20	-	A.6.1	CISO
1.3	Tolerancia cuantificada?	# dims	Art. 5	Art. 18	-	A.12.1	Chief Risk Officer
1.4	Inventario completo?	% discrepancy	Art. 6,28	Art. 18	-	A.8.1	Chief Architect
2.1	Stakeholders consultados?	# groups	Art. 5,14	-	Art. 13-14	A.5.1	Product Manager
2.2	Risk matrix definida?	% uso	Art. 5,9	Art. 18	-	A.12.6	Chief Risk Officer
3.1	Accuracy monitoreado?	≥95%	Art. 15	-	-	A.14.2	Data Science
3.2	Fairness auditado?	<5% gap	Art. 14-15	-	Art. 9	A.14.2	Ethics Officer
3.3	Explainabilidad?	>95% coverage	Art. 50	-	Art. 13	A.14.2	Product Manager
3.4	MTTD <15 min?	Minutes	-	Art. 18,20	-	A.12.4	CISO
4.1	MTTR <30 días?	Days	Art. 15	Art. 18,20	Art. 33	A.16.1	Incident Response Lead
4.2	Validación 100%?	% auditado	Art. 43	Art. 18	-	A.14.2	Chief Auditor

VII. ROADMAP DE CONFORMIDAD REGULATORIA (2026)

Q1 2026 (Ene-Mar)

- EU AI Act Chapters I-II operativo (2 Feb)
- GOVERN: Política, RACI, Risk tolerance documentadas
- AESIA comienza operaciones (enforcement prep)
- Baseline compliance posture assessment

Q2 2026 (Abr-Jun)

- EU AI Act Art. 28-99 pre-operativo (auditorías sin sanciones aún)
- MEASURE: Fairness audits piloto; accuracy monitoring en vivo
- NIS2: Assessment completado para 12 sectores críticos
- High-risk AI systems registrados en EU database (deadline antes Aug 2)
- External compliance audit: identify remaining gaps

Q3 2026 (Jul-Sep)

- EU AI Act Art. 50 operativo (2 Aug): Transparency requirements
- MANAGE: Incident response playbooks en producción
- SIEM MTTD <15 min target operacionalizado
- Compliance re-assessment: % posición target 3.5+ NIST
- Preparar documentación para AESIA first-wave audits

Q4 2026 (Oct-Dic)

- AESIA enforcement begins: potential fines €2-35M
- All remediation gaps closed; re-assessment shows Nivel 3.0+
- Board reporting: compliance maturity scorecard
- Plan 2027: continuous optimization towards Nivel 4.0

Fin de Mapeo Detallado

Documento técnico profesional

Enero 2026 | España | Confidencial